

ACTIVIDAD 11 DE 46 - ANALISIS DE RED: NMAP Y CURL SOBRE TU API

Segunda hora de clase (50 minutos) | Trabajo practico asistido con IA

Herramienta principal: opencode (CLI). Alternativas: ChatGPT, Claude, Copilot, Gemini.

Base normativa / marco de referencia: Evaluacion de riesgos GR.2; superficie de exposicion (Marco Agesic); uso etico y legal

1. Contexto

Un RSI debe conocer la superficie de exposicion de sus sistemas. En un laboratorio local (tu propia maquina), instalaras nmap para descubrir servicios expuestos y usaras curl para probar la API. **IMPORTANTE:** siempre sobre sistemas propios o autorizados; nunca sobre terceros sin permiso.

2. Marco teorico

¿Que es el analisis de red?

Es el reconocimiento de los sistemas visibles en una red: que equipos hay, que puertos estan abiertos y que servicios corren.

Nmap

Nmap es una herramienta gratuita de escaneo de redes, estandar en seguridad.

- Escaneo de puertos: descubre que puertos responden.
- Deteccion de servicios: identifica que servicio corre (web, ssh, base de datos).
- Solo se usa en sistemas propios o autorizados.

Superficie de exposicion

Cada puerto abierto es una posible entrada. El RSI debe conocer la superficie y reducirla a lo necesario.

Limitaciones

El escaneo muestra servicios visibles, no vulnerabilidades internas: para eso van los analisis de la actividad 5 y 35.

3. Objetivos de aprendizaje

- Instalar nmap y entender sus modos de escaneo.

- Identificar servicios y puertos abiertos en localhost.
- Relacionar los servicios encontrados con activos del inventario.
- Documentar la superficie de exposicion y su riesgo.

4. Herramientas del dia (instalacion paso a paso)

nmap (escaneo de red gratuito)

Descubre equipos, puertos y servicios en una red. Se usa de forma etica solo sobre sistemas autorizados.

1. Descarga e instala desde <https://nmap.org> (instalador para Windows).
2. Verifica: ``nmap --version``.

curl (ya instalado)

Probara los endpoints de la API encontrados por nmap.

3. Ya instalado desde la Actividad 4.

5. Desarrollo paso a paso

Paso 1: Levantar la API

Ejecuta tu API de la Actividad 4 (puerto 5000).

Paso 2: Escanear localhost

Ejecuta ``nmap -sV localhost`` y observa los puertos y servicios detectados.

Paso 3: Escanear el puerto de la API

Ejecuta ``nmap -p 5000 -sV localhost`` para ver la version del servicio.

Paso 4: Identificar servicios

Identifica que otros servicios expuestos encuentres (por ejemplo, 135, 445, 5040).

Paso 5: Probar con curl

Usa curl para verificar que los endpoints de la API responden.

Paso 6: Relacionar con activos

Vincula cada servicio encontrado con los activos del inventario (Actividad 4 del modulo documental).

Paso 7: Capturar evidencias

Guarda salidas de nmap y curl.

Paso 8: Documentar y reflexionar

Escribe el informe y tu reflexion.

6. Prompts sugeridos para la IA (opencode)

Copia y adapta estos mensajes en opencode (comando interactivo o `opencode` en terminal).

Explicame esta salida de nmap: [pega la salida]. ¿Que servicios son, que riesgos representan si estan expuestos y como se mitigan?

¿Cuales son los puertos y servicios que jamas deberia estar expuestos en una red financiera?

Dame una politica de escaneo de red etico para un equipo de seguridad: autorizacion, alcance, horarios y evidencia.

7. Documentacion del RSI (bitacora)

Registra en `bitacora.md` de la carpeta de la actividad:

- Resultado del escaneo de localhost.
- Servicios identificados y versiones.
- Relacion servicio-activo del inventario.
- Nota legal: solo se escanean sistemas propios/autorizados.

8. Evidencias a capturar y guardar

Guarda cada evidencia en la carpeta `evidencias/` con el nombre EVI-YYYY-MM-DD-NN-descripcion.ext y registrala en la bitacora.

- EVI-...-01-nmap-general.txt (escaneo de localhost).
- EVI-...-02-nmap-api.txt (puerto 5000 con -sV).
- EVI-...-03-curl-api.txt (respuestas de los endpoints).
- EVI-...-04-exposicion.png (mapa servicio-activo).

9. Informe segun el marco de referencia

Elabora el informe de la actividad (archivo `informe.md`) que incluya:

- Metodologia del escaneo (etica y autorizacion).
- Servicios expuestos encontrados.
- Riesgo de la superficie de exposicion.
- Medidas recomendadas.

10. Entregable de la clase

Salidas de nmap y curl + mapa de superficie de exposicion + informe.

Anexo A - Informe completo para presentar al BCU

Plantilla del informe ejecutivo que el RSI entregaria al Banco Central del Uruguay (BCU) por la actividad 11 - Analisis de red: nmap y curl sobre tu API. Completa los campos [entre corchetes] con los resultados reales de la actividad y adjunta las evidencias EVI-...

Encabezado del informe

Institucion: Banco Ficticio del Uruguay

Responsable de Seguridad de la Informacion (RSI): [Nombre y cargo]

Destinatario: Banco Central del Uruguay - Superintendencia de Instituciones Financieras

Asunto: Actividad 11 - Analisis de red: nmap y curl sobre tu API

Fecha: [dd/mm/aaaa] | Version: 1.0 | Clasificacion: Confidencial

1. Resumen ejecutivo

[2 a 5 parrafos breves: que se realizo, en que marco normativo, que se encontro, que se corrigio y el estado actual. Debe poder leerse en 1 minuto por un directivo.]

2. Marco normativo y regulatorio aplicable

- Norma de Seguridad de la Informacion y Ciberseguridad del BCU (SF.SEG.08).
- Recopilacion de Normas de Regulacion y Control del Sistema Financiero (RNRCSF).
- Circular sobre gestion de incidentes y notificacion de eventos de ciberseguridad.
- Normativa interna del Banco Ficticio del Uruguay: [politica de seguridad, plan de trabajo RSI].

3. Alcance y metodologia

- Alcance: [activos, procesos, sistemas o areas cubiertos por la actividad].
- Metodo: [pruebas tecnicas, revision documental, simulacion, escaneo, etc.].
- Herramientas utilizadas: nmap (escaneo de red gratuito), curl (ya instalado).
- Periodo de ejecucion: [fecha de inicio] a [fecha de fin].

4. Descripcion de la actividad

Un RSI debe conocer la superficie de exposicion de sus sistemas. En un laboratorio local (tu propia maquina), instalaras nmap para descubrir servicios expuestos y usaras curl para probar la API. IMPORTANTE: siempre sobre sistemas propios o autorizados; nunca sobre terceros sin permiso.

5. Resultados obtenidos

- Objetivo: Instalar nmap y entender sus modos de escaneo. -> [Logrado / Parcial / No logrado]
- Objetivo: Identificar servicios y puertos abiertos en localhost. -> [Logrado / Parcial / No logrado]
- Objetivo: Relacionar los servicios encontrados con activos del inventario. -> [Logrado / Parcial / No logrado]
- Objetivo: Documentar la superficie de exposicion y su riesgo. -> [Logrado / Parcial / No logrado]

6. Riesgos identificados y evaluacion

Tabla de riesgos detectados con impacto en la institucion financiera:

ID Riesgo	Descripcion	Probabilidad	Impacto	Nivel	Tratamiento
R-01	[riesgo encontrado]	[A/M/B]	[A/M/B]	[C/E/M]	[Mitigado / Aceptado / En plan]
R-02	[riesgo encontrado]	[A/M/B]	[A/M/B]	[C/E/M]	[Mitigado / Aceptado / En plan]

7. Controles implementados

Descripcion de los controles aplicados y su estado:

- Control: Instala y ejecuta nmap correctamente -> [Implementado / Parcial / Pendiente]
- Control: Identifica servicios y puertos -> [Implementado / Parcial / Pendiente]
- Control: Relaciona servicios con activos -> [Implementado / Parcial / Pendiente]
- Control: Prueba la API con curl -> [Implementado / Parcial / Pendiente]
- Control: Aplica criterios eticos y documenta -> [Implementado / Parcial / Pendiente]

8. Incidentes de seguridad relacionados

[Ninguno en esta actividad. O bien: fecha, tipo, clasificacion, datos afectados, impacto y medidas adoptadas. Si corresponde, nota que ya se notifico al BCU en los plazos reglamentarios.]

9. Indicadores y metricas de la actividad

- Tiempo de ejecucion: [X] horas.
- Hallazgos: [X] altos, [X] medios, [X] bajos.
- Hallazgos corregidos: [X] / [X].
- Cobertura: [X]% de los activos del alcance.

10. Plan de accion y proximos pasos

Accion	Responsable	Plazo	Estado
[accion pendiente]	[cargo]	[dd/mm/aaaa]	Pendiente

11. Conclusion

[Conclusion ejecutiva: postura de seguridad de la institucion tras la actividad y compromiso de seguimiento.]

12. Firma y aprobacion

Firma del RSI: _____ Fecha: [dd/mm/aaaa]

Visto bueno del area de negocio / Direccion: _____

Anexos: evidencias EVI-... registradas en la bitacora.

Anexo B - Como presentar la actividad a AGESIC

Guia de estructura y contenido para comunicar la actividad 11 - Analisis de red: nmap y curl sobre tu API a la Agencia para el Desarrollo del Gobierno de Gestion Electronica y la Sociedad de la Informacion (AGESIC), alineada al marco de ciberseguridad de referencia para Uruguay.

Encuadre institucional

- Organismo: Banco Ficticio del Uruguay, dependencia publica.
- RSI: [Nombre y cargo] | Correo: [correo institucional].
- Fecha de presentacion: [dd/mm/aaaa] | Periodo cubierto: [periodo].

1. Presentacion del responsable

Quien es el RSI, su rol, a que direccion reporta y como se vincula con la gestion de la seguridad de la informacion en el Banco Ficticio del Uruguay.

2. Objetivo de la actividad

Un RSI debe conocer la superficie de exposicion de sus sistemas. En un laboratorio local (tu propia maquina), instalaras nmap para descubrir servicios expuestos y usaras curl para probar la API. IMPORTANTE: siempre sobre sistemas propios o autorizados; nunca sobre terceros sin permiso.

- Objetivo: Instalar nmap y entender sus modos de escaneo.
- Objetivo: Identificar servicios y puertos abiertos en localhost.
- Objetivo: Relacionar los servicios encontrados con activos del inventario.
- Objetivo: Documentar la superficie de exposicion y su riesgo.

3. Marco de referencia utilizado

- Marco normativo de ciberseguridad aplicable (AGESIC / normativa nacional).
- Ley 18.331 de Proteccion de Datos Personales y su Decreto Reglamentario.
- Guia o documento de base: Evaluacion de riesgos GR.2; superficie de exposicion (Marco Agesic); uso etico y legal
- Estandares de buenas practicas: [ISO/IEC 27001, NIST CSF, OWASP, etc.].

4. Metodología y herramientas

Como se desarrollo la actividad y con que herramientas (nmap (escaneo de red gratuito), curl (ya instalado)).

5. Resultados y evidencias

Descripcion de lo obtenido, con referencia a las evidencias guardadas:

- Evidencia: EVI-...-01-nmap-general.txt (escaneo de localhost).
- Evidencia: EVI-...-02-nmap-api.txt (puerto 5000 con -sV).
- Evidencia: EVI-...-03-curl-api.txt (respuestas de los endpoints).
- Evidencia: EVI-...-04-exposicion.png (mapa servicio-activo).

6. Hallazgos, riesgos y recomendaciones

Presentacion de hallazgos ordenados por criticidad y las recomendaciones asociadas:

ID	Hallazgo	Criticidad	Recomendacion	Estado
H-01	[hallazgo]	[C/A/M/B]	[recomendacion]	[Abierto / Cerrado]

7. Gestion de incidentes (si aplica)

- Tipificacion del evento y datos involucrados.
- Notificacion a la Unidad Reguladora y de Control de Datos Personales si se vieron afectados datos personales.
- Lecciones aprendidas y mejoras al plan de respuesta.

8. Plan de mejora y continuidad

Mejora planificada	Responsable	Plazo	Prioridad
[mejora]	[cargo]	[dd/mm/aaaa]	[A/M/B]

9. Compromisos y firmas

El Banco Ficticio del Uruguay se compromete a [seguimiento, capacitacion, revision periodica] y presenta este informe para conocimiento de AGESIC.

Firma del RSI: _____ Sello del organismo: _____

11. Rubrica de evaluacion

Criterio	Logrado (3)	En desarrollo (2)	No logrado (1)
Instala y ejecuta nmap correctamente			
Identifica servicios y puertos			
Relaciona servicios con activos			
Prueba la API con curl			
Aplica criterios eticos y documenta			

12. Checklist de cierre

- ☐ Ejecuté nmap sobre localhost.
- ☐ Identifiqué los servicios expuestos.
- ☐ Documenté la superficie de exposicion.

13. Reflexion sobre el uso de IA

¿Por que conocer tu propia superficie de exposicion es parte de la evaluacion de riesgos? ¿Que diferencia hay entre escaneo etico y ataque?